



Lokalt nettverk

ING3508 Militær informasjonsinfrastruktur

Gruppe 9

16.10.2025

Sammendrag

Gjennom rapporten blir det presentert et foreslått nettverksoppsett for det lokale nettverket i Rukla-Leiren. Formålet med rapporten er å opprette et akseptabelt sikkerhetsnivå på nettverket, samtidig med å ivareta operative og administrative behov, uten å påvirke funksjonalitet eller kreve nyanskaffelser av ressurser.

Det eksisterende nettverket i Rukla-leiren har store sikkerhetsmangler, noe som medfører stor sannsynlighet for at viktige tjenester blir utilgjengelige. Manglende segmentering, overvåkning, og andre sikkerhetstiltak gjør at videre bruk av nettverket vurderes som uforsvarlig. Det nye designet adresserer problemene gjennom en rekke designkrav som har blitt utarbeidet på bakgrunn av prinsipper for et sikkert INI.

Designet er basert på en "hub-spoke" -løsning hvor BNHQ er hub, og de andre byggene fungerer som spokes. Det brukes VRF-lite, GRE-tunneler og IPsec for å muliggjøre løsningen, samt gjøre den sikrere. Dette gjør også at løsningen kan brukes mer sikkert over et WAN som LitVPN, hvor man selv ikke har kontroll.

Gjennom designkravene har det blitt gjort konkrete tiltak for å løse sikkerhetsmangler. For å løse problemer med segmentering er det tatt i bruk logiske løsninger som VLAN og VRF-LITE, samt fysisk segmentering gjennom f.eks. å ha høygraderte systemer i egne soner. For overvåking av nettverket blir det brukt Security Onion med SYSLOG, og ERSPAN som speiler all nettverkstrafikk fra enheter til en sentral overvåkningsserver. For aksesskontroll benyttes 802.1X-portautentisering, RADIUS/AAA og ACL. Samlet gjør tiltakene nettverket sikrere.

Testing av nettverket med de nye sikkerhetsmekanismene har verifisert løsningen. Testingen har blitt gjort både gjennom Cisco packet tracer, og en fysisk simulering av nettverket. Mangel på samlet test på fysisk nettverksutstyr skapte generell usikkerhet. I tillegg til at RADIUS og nettverkovervåkings løsningene ikke er verifisert. Nettverket oppfyller derimot designkravene i stor grad, samtidig som funksjonalitet og brukervennlighet beholdes.

Tabeller, figurer, kodeblokker og vedlegg er ikke inkludert i ordtellingen.

Forkortelser

Informasjonsinfrastruktur	INI
Dynamic Host Configuration Protocol	DHCP
Internet Protocol	IP
Media Access Control-adresse	MAC
IP Source Guard	IPSG
Spanning-Tree Protocol	STP
Bridge Protocol Data Units	BPDU
Address Resolution Protocol	ARP
Dynamic ARP Inspection	DAI
Virtuel- / Local Area Network	VLAN / LAN
Secure Shell	SSH
Network Time Protocol	NTP
Virtual Private Network	VPN
Virtual Routing and Forwarding	VRF
Wide Area Network	WAN
Access Control List	ACL
Remote Authentication Dial-in User Service	RADIUS
Authentication Authorization Accounting	AAA
System Logging Protocol	Syslog
Institute of Electrical and Electronics Engineers	IEEE
Battalion Headquarters	BNHQ
Internet Service Provider	ISP
Encapsulated Remote SPAN	ERSPAN
Switched Port Analyzer	SPAN
Port Address Translation	PAT

[Denne siden er blank med hensikt]

Innholdsfortegnelse

1 Introduksjon	1
1.1 Bakgrunn og problemformulering	1
1.2 Forutsetninger og begrensninger	1
2 Teori	2
2.1 DHCP snooping	2
2.1.1 IPSG	2
2.2 STP	2
2.2.1 BPDU Guard, PortFast og Loop Guard	3
2.3 DAI	3
2.4 Sikkerhetsovervåkning og logging	4
2.4.1 Security Onion	4
2.4.2 Syslog	4
2.4.3 ERSPAN	4
2.5 EtherChannel	5
2.7 SSH	5
2.8 NTP	5
2.9 Tunnellering og VRF-Lite	5
2.10 IPSec	6
2.11 802.1X-standard	6
2.12 ACL	7
2.13 PAT	7
3 Design	8
3.1 Designkrav	8
3.2 IP-addresseringsplan	9
3.3 Fysisk design	10
3.4 Hub-spoke arkitektur	11
3.5 Logisk design	12
3.6 Nettverkssikkerhet	14
3.6.1 Sikkerhetsovervåkning og logging	14
3.6.2 Sikkerhetstiltak og konfigurasjon	15
4 Test og verifikasjon	17
5 Diskusjon	20
5.1 Ruting, utstyr og adresseplan	20
5.2 Kryptering og sikkerhet	20
5.3 Tilgangskontroll og autonomi	21
5.4 Redundans og skalerbarhet	21
5.5 Sikkerhetsovervåkning, logging og arkitektur	21
5.6 Ikke tekniske aspekter	22
5.7 Test og verifikasjon	22

6 Konklusjon	23
7 Referanseliste	24
Vedlegg 1 KOMSS og BIFSMARKS	27
Vedlegg 2 Detaljert nettverkskisse	29
Vedlegg 4 Nettverksovervåkning	30

1 Introduksjon

1.1 Bakgrunn og problemformulering

Den norske S6-seksjonen i NATO Enhanced Forward Presence Battlegroup Lithuania har overtatt ansvaret for nettverket i Rukla-leiren. Nettverket støtter operative og administrative behov. Nettverksinfrastrukturen har mangel på segmentering, dokumentasjon og sikkerhetsmekanismer. Nettverket brukes av hele bataljonen, private klienter og ukontrollerte enheter. Det er altså tydelige sårbarheter i nettverket. Denne rapporten har derfor til hensikt å finne løsninger for å minimere dagens utfordringer. Samtidig som dagens brukervennlighet og funksjonalitet i nettverket bevares. Rapporten skal også fungere som en detaljert dokumentasjon av design som tilrettelegger for drift og vedlikehold for fremtidige kontingenter.

1.2 Forutsetninger og begrensninger

Materiell som er til disposisjon kan bli konfigurert og brukt. Dette er totalt 36 1Gbps svitsjer og én ruter. I tillegg har vi tre eldre Cisco rutere og fem 1Gbps svitsjer som er tiltenkt for testing før de kan brukes på nettet. Det vi trenger av kabler og tillatelse til å bruke seksjonens lab-klienter i oppsettet er inkludert. Ingen endring på produksjonsnettet er tillatt uten godkjennelse fra S6 etter testing og verifisering av funksjonalitet. Brukerne skal fremdeles få samme funksjonalitet fra nettet. Vi kan ikke endre på det som er levert av det Litauiske forsvaret siden det er ansett som for ressurskrevende. Dette inkluderer spesielt litVPN nettet. Det er ingen midler til nyanskaffelser.

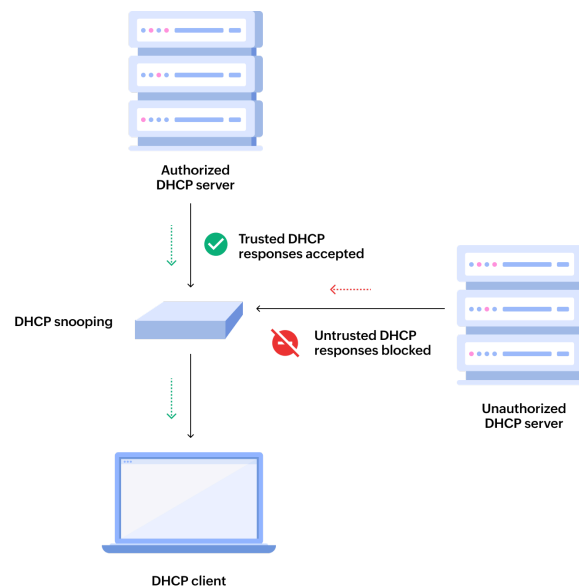
2 Teori

Kapitlet omhandler nødvendig teori om tjenester og funksjoner som benyttes.

Løsningene baseres på krav om forsvarbar INI (KOMSS), og NATOs CIS-doktrine for ideelle egenskaper for militær INI (BIFSMARKS)[1]. Se vedlegg 1.

2.1 DHCP snooping

DHCP tildeler IP-adresser og nettverksparametere automatisk. DHCP snooping er en sikkerhetsmekanisme for DHCP-trafikk som blokkerer uautoriserte servere. DHCP snooping definerer betrodde og ikke-betrodde porter som vist i figur 1. Sikrer at kun gyldige DHCP-svar når klientene. Svitsjene oppretter også en bindingstabell som kan benyttes av andre sikkerhetsfunksjoner[2].



Figur 1 - DHCP snooping [2]

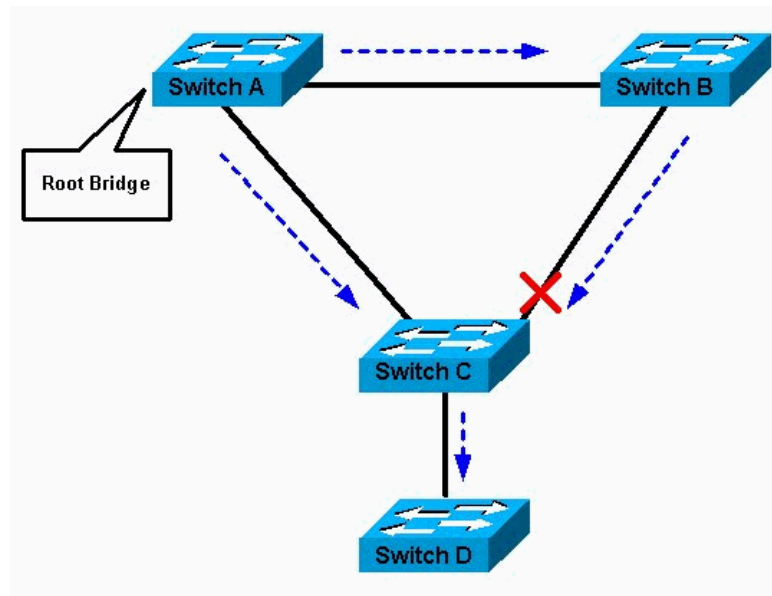
2.1.1 IPSG

IPSG beskytter mot IP-spoofing på porter, ved å blokkere trafikk med falsk IP-adresse. Sikkerhetsfunksjonen bruker databasen fra DHCP snooping for å sjekke at trafikken kommer fra riktig IP-adresse, ellers blir trafikken blokkert[3].

2.2 STP

Redundante linker mellom svitsjer kan skape ARP-loops, hvor ARP-pakker sirkulerer uendelig noe som overbelaster og gjør nettet utilgjengelig.

STP oppdager og blokkerer overflødige linker i et svitsj nett med BPDUs. BPDUs finner den mest effektive veien mellom en hovedsvitsj (Root) og andre svitsjer. Blokkerte veier/porter kan aktiveres dersom den aktive forbindelsen feiler. Konseptet er vist i figur 2[4].



Figur 2 - Spanning Tree Protocol [4]

2.2.1 BPDU Guard, PortFast og Loop Guard

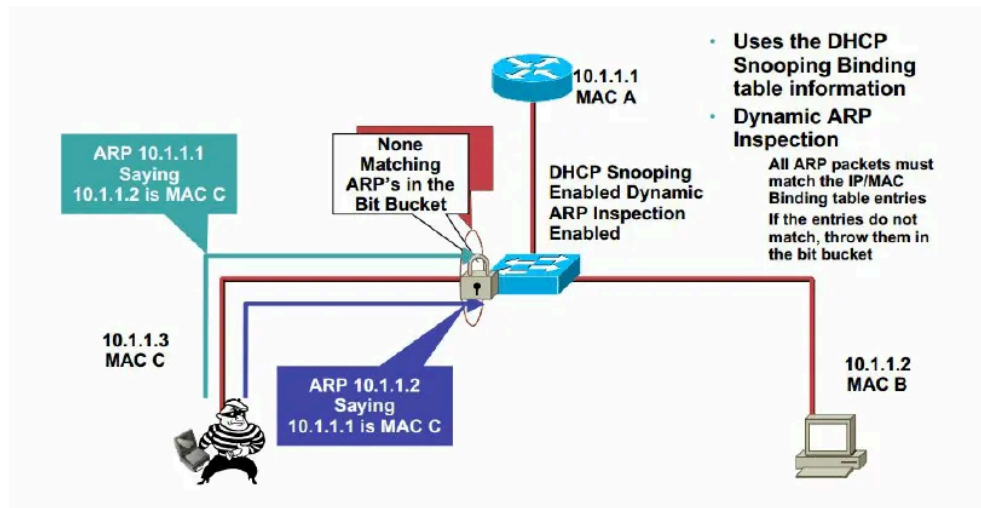
BPDU Guard deaktiverer porter som mottar BPDUs, og dermed beskytter nettverket mot feil eller uautoriserte svitsjer.

PortFast får klientporter til å hoppe over STP-oppsettet og gå direkte til forwarding.

Loop Guard er en funksjon som deaktiverer porter om en forbindelse slutter å motta eller sende BPDUs, og beskytter mot loops i form av *“unidirectional link failures”*[4].

2.3 DAI

DAI beskytter mot ARP-spoofing. DAI forhindrer utnyttelse av dette ved å kontrollere ARP-meldinger opp mot DHCP snooping databasen (eller statiske bindinger) og blokkere trafikk som ikke stemmer. som vist i figur 3[5].



Figur 3 - Dynamic ARP Inspection

2.4 Sikkerhetsovervåkning og logging

Overvåking og logging av nettverket gir muligheten til å oppdage mistenkelig aktivitet, og analyse av hendelser, noe som tilrettelegger for hendelsehåndtering.

2.4.1 Security Onion

Security Onion er en gratis og åpen plattform for sikkerhetsovervåkning. Security Onion samler forskjellige verktøy som gir innsikt i nettverkstrafikk, og har funksjoner for logghåndtering[6].

2.4.2 Syslog

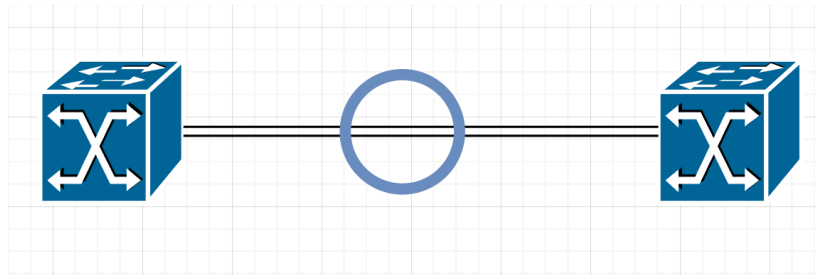
Syslog er en protokoll som brukes til å samle systemmeldinger fra Cisco-enheter og sende dem til en server som eksempelvis security onion, der meldingene mottas, lagres og kan analyseres over tid[7].

2.4.3 ERSPAN

ERSPAN lar deg speile trafikk fra porter eller VLAN og sende den som GRE-innkapslet trafikk til en ekstern enhet for overvåkning og analyse[8].

2.5 EtherChannel

Etherchannel kombinerer flere ethernet kabler til én logisk forbindelse som vist i figur 4.



Figur 4 - EtherChannel

Dette øker overføringskapasiteten samtidig som det bidrar til redundans og robusthet hvis en port eller kabel feiler[9].

2.7 SSH

Det er ønskelig at managementklienter i et nettverk kan fjernstyre enheter for drift og vedlikehold. Dette bidrar til fleksibilitet, skalerbarhet og interoperabilitet. SSH v2 er en sikker kryptert form fjernstyring som benyttes[10].

2.8 NTP

For at loggene fra enhetene i nettet skal kunne sammenlignes ved en feil eller hendelse, er tidssynkronisering en fordel. De interne klokke i svitsjer og rutere vil avvike overtid. NTP løser dette ved at enhetene benytter en NTP-server til å få tiden[11].

2.9 Tunnellering og VRF-Lite

Tunnellering lar oss koble sammen nettverk over et WAN uten at WAN'et trenger å vite noe om de private nettverkene. For å oppnå dette må tunnelene kjenne både egen og motpartens ruters offentlige IP-adresse. I tillegg til en tunnel IP-adresse som sørger for at trafikken blir lest som IP-trafikk. For å skille tunnelene brukes en "tunnel key" som vil være unik identifikator for hver tunnel. For å beholde VLAN i rutingen, må det opprettes

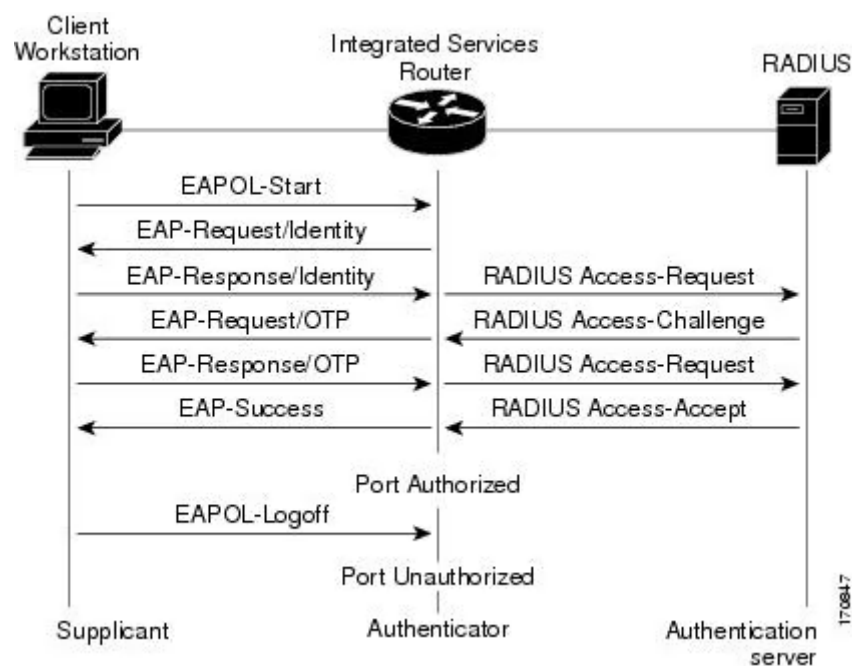
uavhengige rutingstabeller. For dette brukes VRF-Lite, som lager virtuelle rutere i ruterne, hvor hver har egne rutingstabeller[12][13][14].

2.10 IPSec

Kun kilde og destinasjon mellom ruterne vises, ikke innhold eller nettverkstruktur da informasjonen vil bli kryptert[15].

2.11 802.1X-standarden

802.1X er en IEEE standard for portbasert tilgangskontroll der enheter autentiseres før de får tilgang. Når en enhet kobler seg til et aksesspunkt med 802.1X får enheten en forespørsel om å identifisere seg. Identifikatoren blir videresendt til en RADIUS-server, som avgjør VLAN tilgang. Hvis identifikatoren ikke stemmer overens med dem i serveren, får ikke enheten tilgang. Prosessen er vist i figur 5.



Figur 5 -802.1X-standaren

RADIUS-serveren også logger hvem som prøver å logge seg inn, hvor lenge brukeren er tilkoblet og hvor mye data som brukeren overfører[16].

2.12 ACL

ACL styrer trafikk basert på IP, protokoll eller portnummer. ACL kan derfor benyttes for filtrering og isolering av trafikk[17].

2.13 PAT

Port Address Translation (PAT) er en funksjon som skjuler private adresser ved å legge dem bak en offentlig IP-adresse og bruke portnumre for å skille dem fra hverandre[18].

3 Design

Kapittel tre skal gi en oversikt over design, designkrav, og hvordan tjenester og funksjoner er implementert for å møte designkravene.

3.1 Designkrav

Tabell 1 Kravtabell

ID	Krav	Pri.	Designprinsipp/Ideell egenskap	Begrunnelse
1	Nettet skal være segmentert. Minimum i drift, operativ og velferd.	H	Kontroll, sikker, fleksibel.	Segmentering reduserer risiko for kompromittering av nettet. Isolerer drift, velferd og operativ trafikk.
2	Tilgangskontroll til nettet skal være portbasert (802.1X / AAA).	M	Kontroll, sikker, sporbar.	Hindrer at ikke autoriserte personer eller enheter får koble seg til nettet, samtidig som det gir sporbarhet.
3	Uvedkommende skal ikke kunne lese datatrafikken som sendes over nettet.	H	Sikker, motstandsdyktig.	Kryptering av data vil beskytte mot angrep og avlytting.
4	Nettverket skal ha sentral overvåking og logg.	M	Sporbarhet, sikkerhetsmessig overvåking, beredskapsklar.	Tilrettelegger for analyse, overvåking og hendelsehåndtering, forenkler også en HOTO.
5	Brannmur og/eller ACL som styrer data trafikk.	M	Kontroll, minimert, sikker.	Kun nødvendige tjenester får komme igjennom. Begrenser angrepsoverflate.
6	Sluttbrukere skal ikke oppleve noe tap av tjeneste eller funksjonalitet.	H	Kapabel, rettidig, sikker, autonom.	Nettet skal gi samme funksjonalitet som før, men med forbedret redundans og robusthet.
7	Nettverket skal kunne driftes med dagens ressurser.	H	Fleksibel, skalerbart.	Krav fra stabssjef om at det ikke skal forekomme større nyanskaffelser, men nettet må fortsatt være rettet mot utvikling.
8	Systemet skal være oppdatert og unødvendige tjenester fjernet.	M	Oppdatert, minimert, sikker.	Reduserer angrepsoverflaten, mens kjente sårbarheter fjernes.

9	Kritiske tjenester skal fungere hvis kobling blir borte.	M	Autonom, kapabel, rettidig, motstandsdyktig.	Lokale tjenester som interntelefoni og PA-anlegg bør fungere ved tap av VPN til det litauiske forsvaret.
10	Kryptert fjernadministrasjon av enhetene.	M	Sikker, kontrollert.	Effektiviserer drift og vedlikehold.
11	Nettverket bør være skalerbart for flere brukere og tjenester.	L	Skalerbart, fleksibelt.	Effektiviserer eventuell utvidelse av bataljonen eller dens tjenester.

3.2 IP-adresseringsplan

Tabell 2 viser adresseplanen for nettverket.

Tabell 2 - Adresseplan

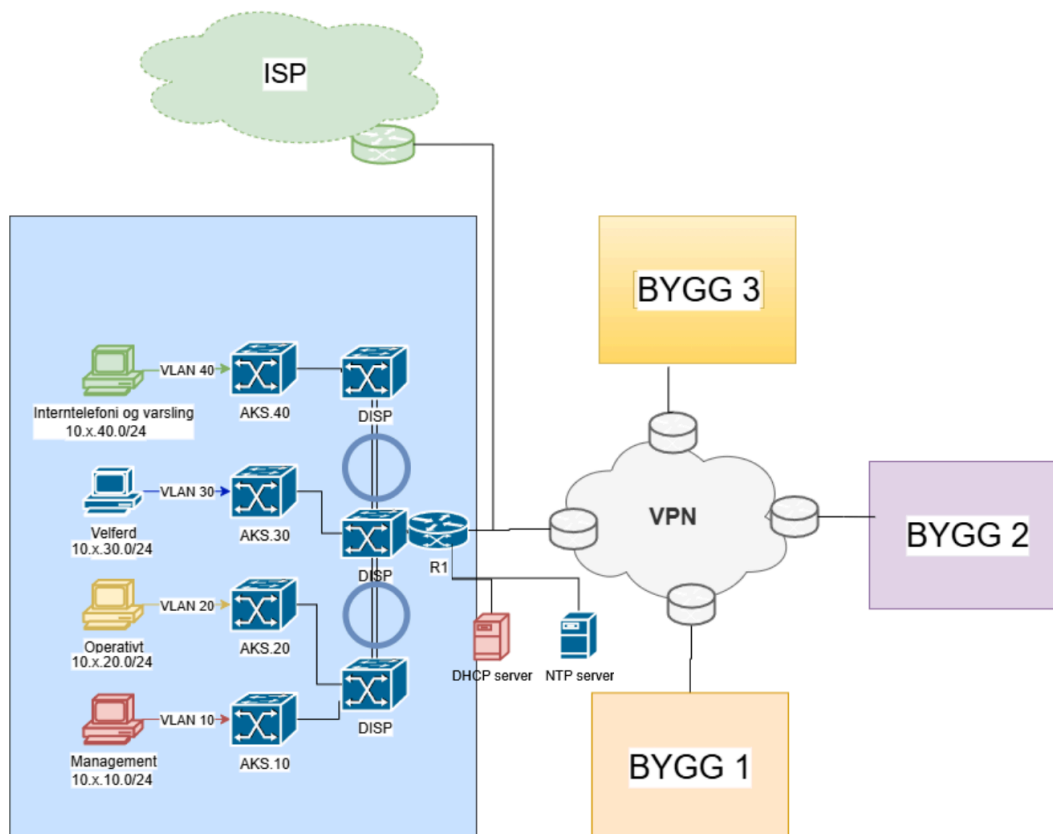
Plassering	Nett-ID	Subnettmaske	VLAN
BN HQ	10.1.10.0/24	255.255.255.0	10 MGMT
BN HQ	10.1.20.0/24	255.255.255.0	20 Operativt
BN HQ	10.1.30.0/24	255.255.255.0	30 Velferd
BN HQ	10.1.40.0/24	255.255.255.0	40 Telefoni
Bygning 1	10.2.10.0/24	255.255.255.0	10 MGMT
Bygning 1	10.2.20.0/24	255.255.255.0	20 Operativt
Bygning 1	10.2.30.0/24	255.255.255.0	30 Velferd
Bygning 1	10.2.40.0/24	255.255.255.0	40 Telefoni
Bygning 2	10.3.10.0/24	255.255.255.0	10 MGMT
Bygning 2	10.3.20.0/24	255.255.255.0	20 Operativt
Bygning 2	10.3.30.0/24	255.255.255.0	30 Velferd
Bygning 2	10.3.40.0/24	255.255.255.0	40 Telefoni
Bygning 3	10.4.10.0/24	255.255.255.0	10 MGMT
Bygning 3	10.4.20.0/24	255.255.255.0	20 Operativt
Bygning 3	10.4.30.0/24	255.255.255.0	30 Velferd
Bygning 3	10.4.40.0/24	255.255.255.0	40 Telefoni

Nettverket benytter IP-adressene i 10.0.0.0/8-nettet. Andre oktett beskriver hvilken bygning undernett er i. Tredje oktett beskriver hvilket VLAN den tilhører. Fjerde

oktett er for IP-adresser, dermed er det 253 mulige klienter for hvert VLAN i hver bygning.

3.3 Fysisk design

Det fysiske designet til nettverket er vist i figur 6, for mer detaljert nettverkskisse, se vedlegg 2.

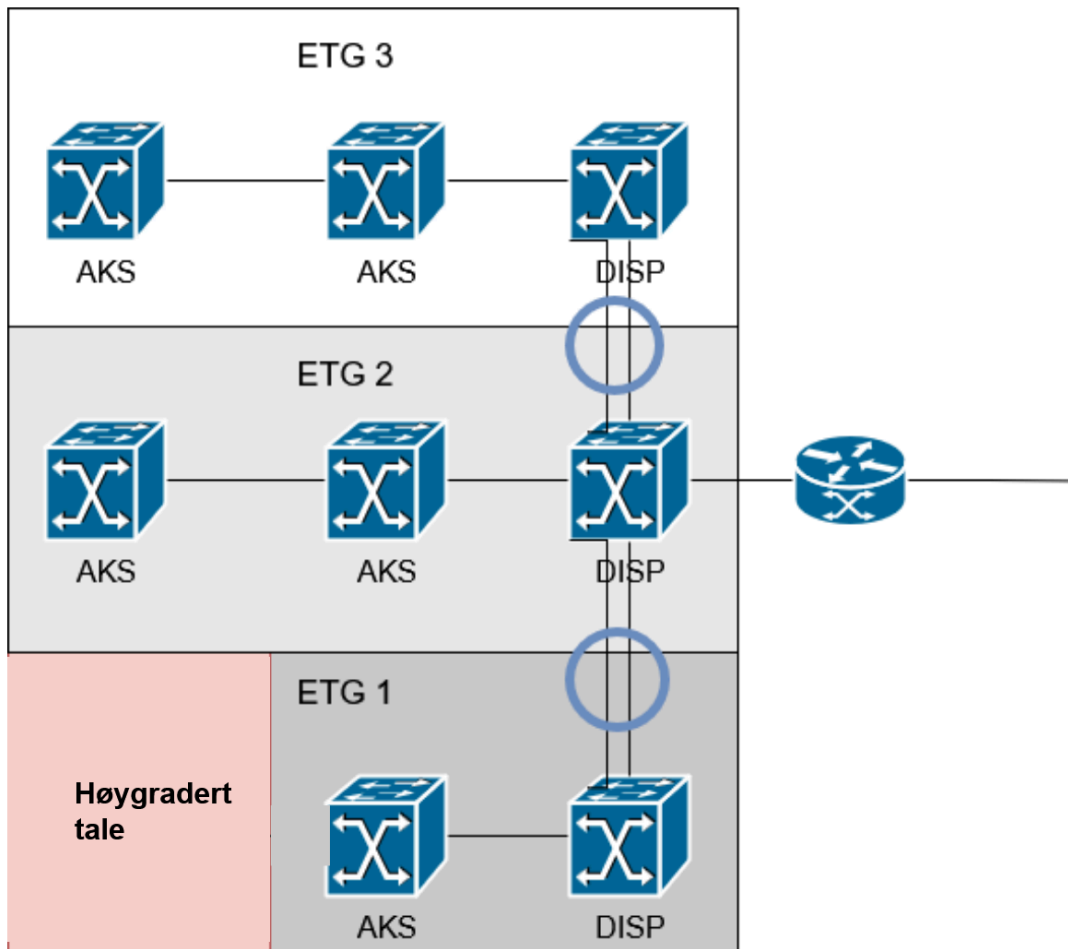


Figur 6 - Fysisk design

Figur 6 viser de forskjellige subnettene og VLANene, hvor "x" er varierende for de forskjellige byggene.

VPN-skyen representerer litVPN. AKS-svitsjene fungerer som aksesssvitsjer for klienter, og DISP er distribusjonssvitsjer. EtherChannel er brukt der det er to parallelle forbindelser. Ruterne for hvert bygg benyttes som DHCP-server, og lokal NTP-server inn mot byggene.

7.

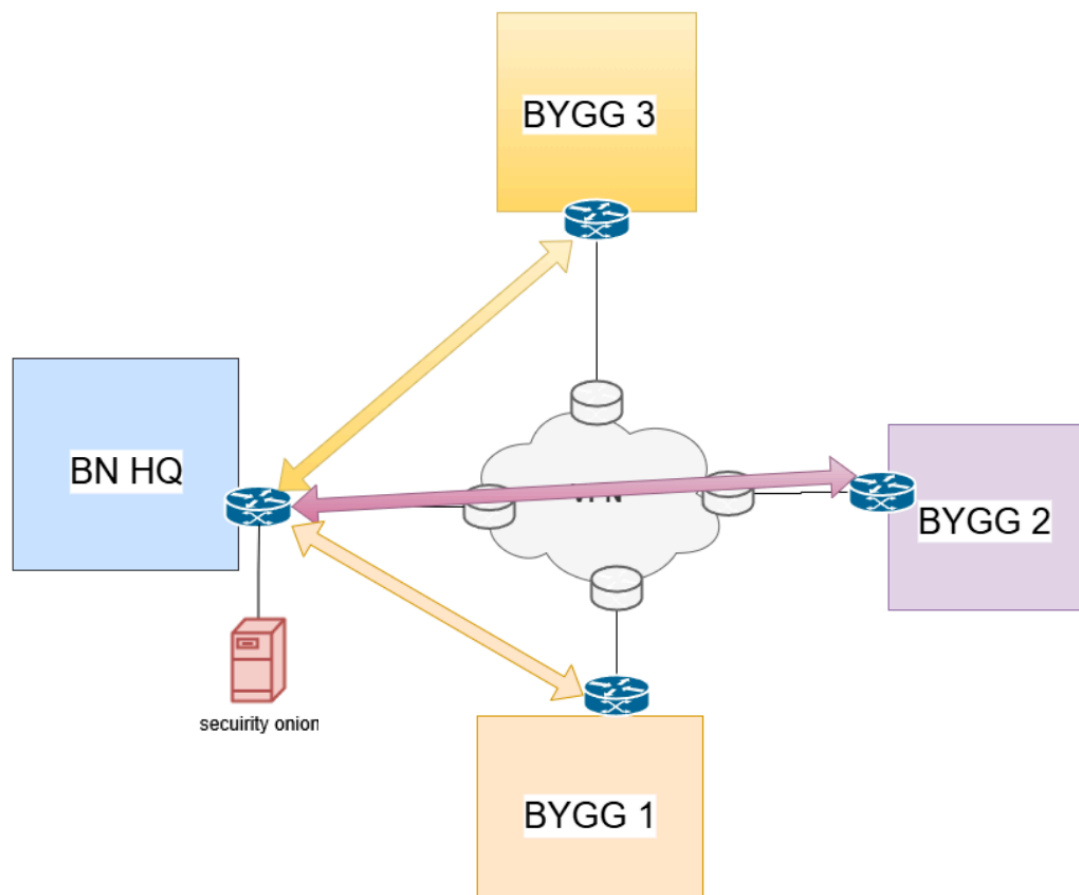


Figur 7- Fysisk design i bygg

Figur 7 viser det fysiske svitsj designet for et bygg, hvor høygradert tale er adskilt fra nettverket i et eget rom. Dette rommet bør være avlåst og være i henhold til virksomhetsforskriften §41[19].

3.4 Hub-spoke arkitektur

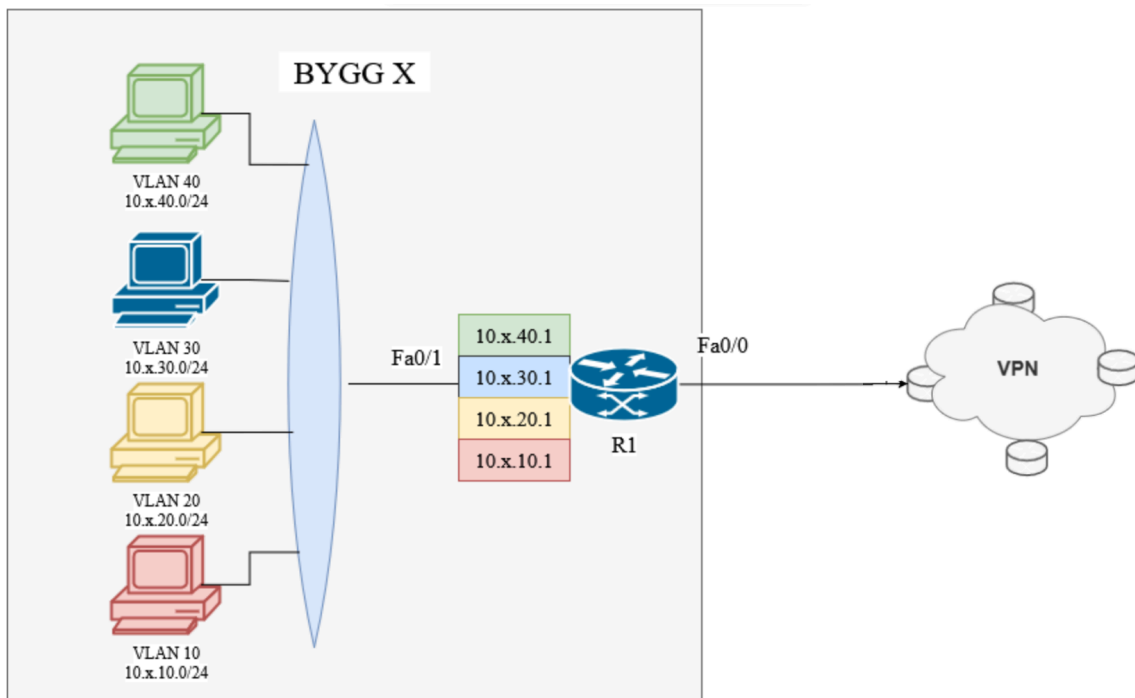
Det benyttes en Hub-spoke arkitektur mellom BNHQ som hub, og byggene som spoke. Kommunikasjon fra byggene går derfor gjennom BNHQ. Dette oppnås ved hjelp av VRF-Lite og GRE-tunneler i kombinasjon med IPsec. Dette øker sikkerheten over et ukontrollert WAN, som vi har fra LitVPN. I BNHQ har vi sentral logging gjennom security onion. Arkitekturen for kommunikasjonen er vist i figur 8 nedenfor.



Figur 8 - Hub-spoke arkitekturen

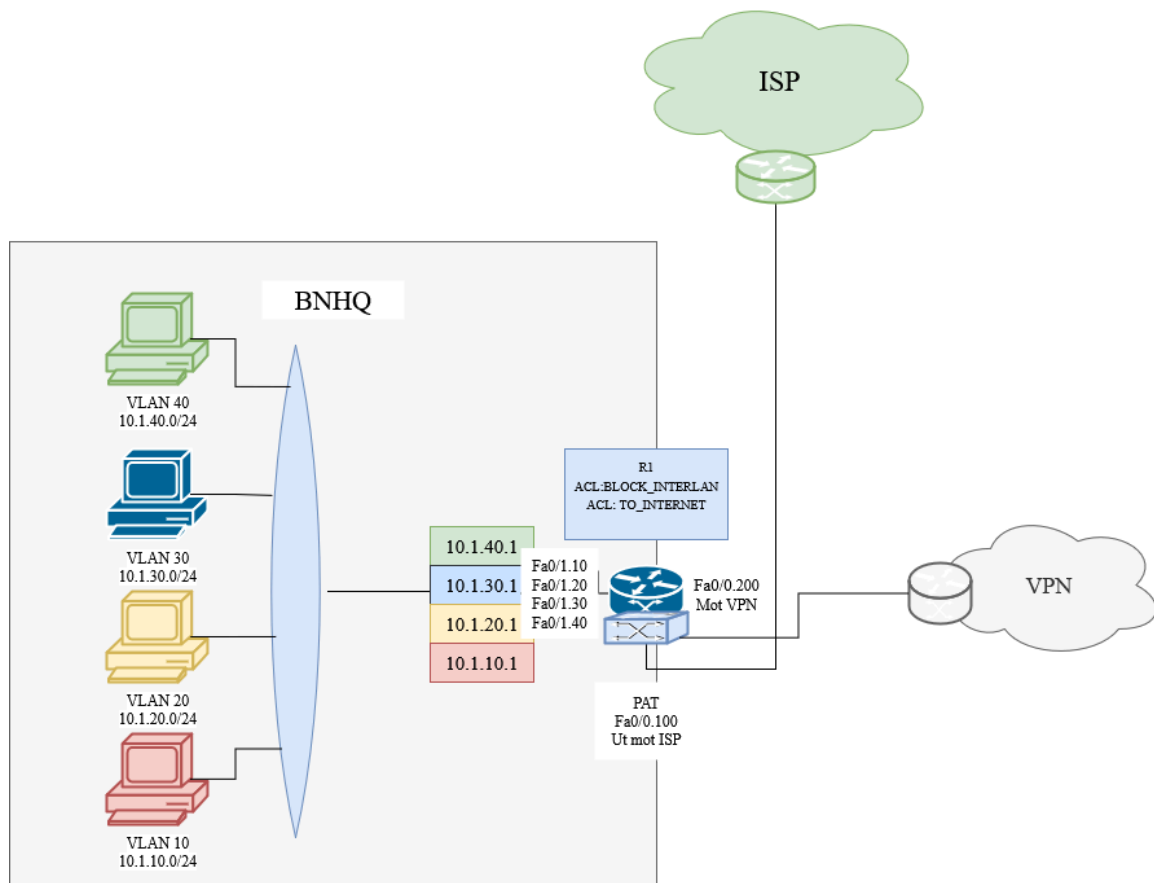
3.5 Logisk design

Figur 9 viser det logiske designet for bygg 1, 2 og 3. Figuren viser gateway adresser for VRF-Lite og DHCP serveren for de forskjellige VLANene, samt porter som benyttes ut mot ruter.



Figur 9 - Logisk skisse: bygg 1, 2 og 3

Det logiske designet for BNHQ for ruting ut til internett er vist i figur 10.



Figur 10 - Logisk skisse: BNHQ

I BNHQ benyttes ACL istedenfor VRF-lite. Ruterens har derfor en global rutingsstabell, og all data fra bygg går inn mot samme subinterface (Fa0/0.200). ACL benyttes for å hindre at trafikk mellom bygg blandes og interne som MGMT ikke går ut mot ISP. Port subinterface Fa0/0.100 er mot internett. Ruting til bygg og internett er derfor statisk konfigurert, og kombinasjon av ACL og PAT for å kunne rute data til internett. Ruterens interne svitsj benyttes til distribusjon av data, og er konfigurert som trunk (Fa1/0) med to aksessporter (Fa1/1 for ISP, Fa1/2 for VPN).

3.6 Nettverkssikkerhet

3.6.1 Sikkerhetsovervåkning og logging

Security Onion serveren er tilkoblet management-VLAN 10, plassert i BNHQ med en statisk IP-adresse som vist i figur 8. Dermed kan den administreres sentralt, og motta

trafikk- og loggdata fra alle bygg. Rutere og svitsjer er konfigurert til å sende syslog til Security Onion, slik at eventuelle hendelser og feilmeldinger er samlet.

For overvåking av trafikk benyttes ERSPAN til å speile pakker fra kritiske VLAN, som operativ-, velferd- og internettsonene. Trafikken analyseres av Security Onion, som gir varsling ved deteksjon av trusler og innsikt i protokollbruk.

Designet krever kun én fysisk Ethernet-port, siden all kommunikasjon går over eksisterende VPN-forbindelser. Løsningen er skalerbar og kan enkelt utvides til å inkludere flere VLAN eller bygg etter behov.

Hver bygning har sin egen RADIUS-server som håndterer autentisering og autorisasjon. Ved å ha en sentral RADIUS-server i hvert bygg, oppnås autonomi og redundans, samtidig som tjenesten gir kontroll og sikkerhet. I tillegg benyttes RADIUS til loggføring, noe som bidrar til sikkerhetsmessig overvåking og sporbarhet.

3.6.2 Sikkerhetstiltak og konfigurasjon

DHCP snooping er aktivert på alle svitsjene. Porter som leder mot DHCP-server er definert som "*trusted*", mens alle andre er "*untrusted*". Slik forhindres uautoriserte DHCP-servere. Databasen som opprettes av DHCP snooping benyttes også for IPSG og DAI.

IPSG er aktivert på klientporter, slik at trafikk fra en klient blir kontrollert om det samsvarer med registrerte IP-adresser i DHCP-snooping databasen. Pakker med IP-adresser som ikke stemmer blir blokkert, noe som hindrer IP-spoofing.

DAI er også konfigurert på svitsjene i nettverket. Funksjonen validerer ARP-meldinger opp mot DHCP-snooping databasen, og blokkerer ugyldige forespørsler. Således beskyttes nettverket mot ARP-spoofing og man-in-the-middle-angrep.

For å sikre stabilitet og redundans i nettverket er STP aktivert. Edge-porter er konfigurert med Portfast for å redusere oppstartstiden for klienter, samtidig som BPDU Guard er aktivert for å forhindre at svitsjer utilsiktet kobles til slike porter. På trunk-porter er Loop Guard aktivert for å beskytte mot feil i forbindelser som kan føre til loops. Dette gjør at nettverket kan ha redundante forbindelser uten risiko for overbelastning eller nedetid.

802.1X-portautentisering er aktivert ved alle aksessporter. Standarden sørger for at enheter må autentisere seg mot en sentral RADIUS-server før de får tilgang til nettverket. VLAN'et enheten blir tilgitt bestemmes da av RADIUS brukeren. Dersom autentisering mislykkes, blir porten blokkert eller plassert i et gjeste-VLAN med begrensede rettigheter. Dette gir et ekstra sikkerhetslag ved å knytte nettverkstilgang til bruker- eller enhetsidentitet, og hindrer uautoriserte klienter i å få full tilgang.

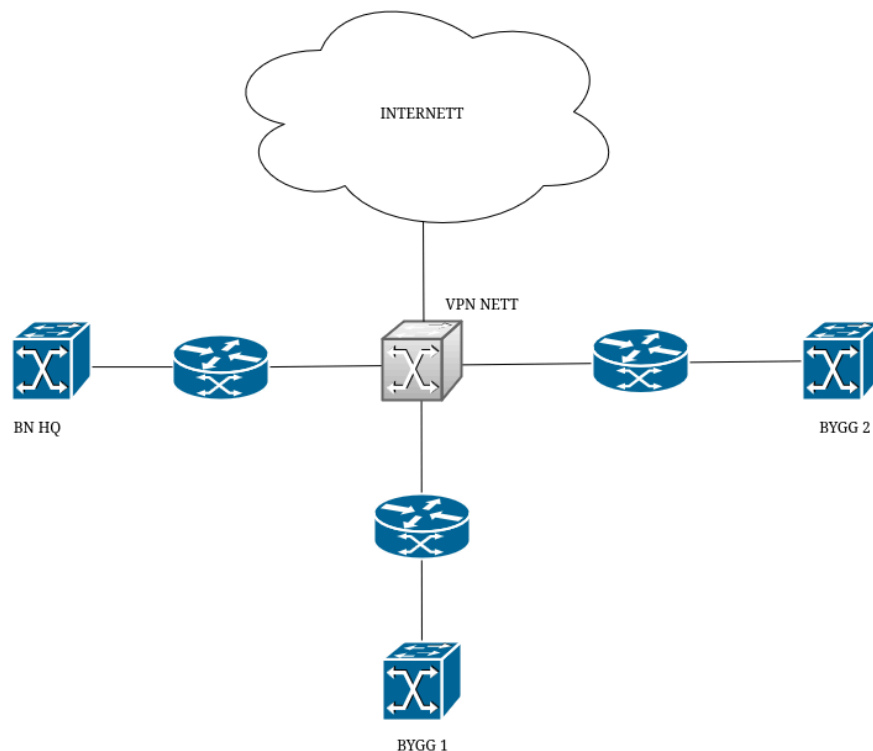
VRF-Lite og ACL for BNHQ er konfigurert hos ruterne i nettverket. De sørger for at gjestenettet kun får tilgang til internett, management kun får interne ressurser, og at øvrige VLAN holdes atskilt etter behov.

For å sikre både integritet og konfidensialitet, benyttes IPsec til å kryptere pakkene. IPsec brukes for kommunikasjon mellom byggene fordi nettverket fra litVPN ikke er under vår kontroll, og det finnes ukontrollerte områder på leieren, slik at uautoriserte aktører ikke kan avlytte trafikken.

Hver svitsj og ruter enhet i nettverket er konfigurert med SSH v2 for sikker fjernadministrasjon.

4 Test og verifikasjon

Hver protokoll og funksjonalitet beskrevet i kapittel 2 har hver sin konfigurasjon som finnes i vedlegg 3. Alt unntatt RADIUS og Security Onion er testet og verifisert separat gjennom Cisco packet tracer. GRE-tunneleringen over IPsec med "Hub and spoke"-arkitekturen og ruting ut mot internett med ACL og PAT er testet og verifisert med fysiske enheter med arkitekturen vist i figur 11.



Figur 11- Oppsett for testing

I figur 11 benyttes en klient laptop som en internettleverandør. Testmatrisen for resultatene av test og verifisering er vist i tabell 3 nedenfor. Grønn er verifisert, rød er ikke verifisert, og gult er delvis verifisert.

Tabell 3 - Testmatrise

Hva som er testet	Resultat
DHCP server	
Etherchannel	
SSH	

NTP	
DHCP snooping	
DAI	
IPSG	
STP(Portfast, loop guard, BPDU guard)	
PAT	
Tunellering (GRE over IPSec)	
Syslog	
Security Onion	
ERSPAN/SPAN	
RADIUS Autentisering	
RADIUS Loggføring	

Nettverksovervåkning ble testet på HUB ruter, hvor det ble satt opp Security Onion, SYSLOG og SPAN hver for seg. ERSPAN fungerer ikke på eldre nettverksutstyr og ble derfor endret til SPAN, som er mindre komplisert. Hver enkelt av overvåkningstjenestene ble testet og verifisert, men det ble ikke verifisert at dataen ble mottatt hos Security Onion serveren. Testen bekreftet derfor at konfigurasjonene på ruterne fungerte som forventet, men faktisk mottak i overvåkingssystemet er ikke bekreftet. Dette er trolig grunnet mangel på sammensatt test, og mulig feil i oppsettet av Security Onion. Konfigurasjon i vedlegg 4.

802.1X ble konfigurert med RADIUS ved hjelp av Freeradius på klient og egne standarder på switch og ruter, men autentiseringen fungerte ikke som forventet. Etter testing ble det oppdaget problemet knyttet til bruk av WSL 2 (Windows Subsystem for Linux), som oppretter virtuelle nettverksportar på PC-en. Dette førte til utfordringer med trafikkflyt mellom nettverksgrensesnittene.

Vi forsøkte deretter å gå over til WSL 1 for å forenkle nettverksforbindelsen, men møtte nye problemer relatert til IP-adressering og kommunikasjon i nettverket. En alternativ løsning kunne vært å benytte en virtuell RADIUS-server via Hyper-V, noe som potensielt

ville gitt bedre kontroll over nettverksoppsettet og porter. På grunn av tidsbegrensninger ble videre testing av RADIUS nedprioritert, og loggføring ble derfor ikke implementert.

5 Diskusjon

Løsningen for nettverket er basert på tjenester og plattformer tilgjengelige på de nettverksenhetene som seksjonen disponerer. Designet er utviklet med utgangspunkt i de formulerte designkravene, samt de ideelle egenskaper (BIFSMARKS) og prinsippene for forsvarbar INI (KOMMS). Hvorvidt designet av nettverket faktisk har oppnådd ønsket effekt og er innenfor et akseptabelt nivå vil bli diskutert i dette kapittelet

5.1 Ruting, utstyr og adresseplan

For ruting ut mot internett måtte ACL benyttes for filtrering av trafikk i BNHQ. Dette var ikke den opprinnelige løsningen, men et nødvendig kompromiss, siden de tilgjengelige ruterne er eldre og har begrenset støtte for moderne funksjoner som VRF-lite med PAT. Eldre utstyr gjelder generelt for alle nettverksenheter som er tilgjengelige, noe som legger en begrensning på hvilke funksjoner og protokoller som er mulige å benytte seg av, eksempelvis bruken av SPAN istedenfor ERSPAN. Nyere utstyr ville nok muliggjøre flere og mer fleksible løsninger, som sannsynligvis vil kunne tilfredsstille designkravene ytterligere.

Adresseplanen er lagt opp med 1000 adresser per VLAN. Det er lite sannsynlig at alle 1250 soldater bruker det samme VLAN-et samtidig, og løsningen anses derfor som tilstrekkelig. Dette møter designkrav 1 om segmentering og designkrav 6 om bevaring av funksjonalitet, samtidig støtter det prinsippene fleksibelt og skalerbart.

5.2 Kryptering og sikkerhet

IPsec-kryptering møter designkrav 3 ved å beskytte dataen mellom bygg mot avlytting. Derimot er ikke krypteringen komplett ende til ende, da den er konfigurert på ruterne. Likevel gir løsningen tilfredsstillende beskyttelse for et ugradert miljø. SSH v2 gir sikker fjernstyringsadministrasjon for å møte designkrav 10. Nyere tjenester for fjernadministrasjon kunne derimot blitt benyttet for utvidet funksjonalitet.

Videre er det satt tiltak for å redusere sårbarheter i nettverket som DAI, DHCP-snooping, og IPSG for å forhindre spoofing og man-in-the-middle-angrep. Dette bidrar til motstandsdyktighet, sikkert og kontrollert, samtidig som det møter designkrav 3. Det er

dessverre ikke mulig å eliminere alle sårbarheter, men disse tiltakene vurderes som akseptable for det ugraderte miljøet.

Brannmur mangler i nettverket og anbefales å implementeres for å oppnå designkrav 5. Både ACL og VRF-lite er konfigurert til å filtrere data, men mangler funksjonene som man får fra en brannmur. Grunnlaget for mangelen er prioritering av tid og ressurser.

5.3 Tilgangskontroll og autonomi

De sentrale AAA/RADIUS-serverne gir både tilgangskontroll og loggføring, og møter dermed designkrav 2 og designkrav 4, samtidig som løsningen bidrar til autonomi.

Løsningen reduserer derimot brukervennligheten, siden hver bruker må autentiseres, noe som kan påvirke designkrav 6. Funksjonaliteten bidrar derimot til en god og nødvendig tilgangskontroll, og det vurderes derfor som et akseptabelt kompromiss mellom sikkerhet og effektivitet.

Ved å ha lokale RADIUS-, DHCP- og NTP-servere i hvert bygg ivaretas designkrav 9 om autonomi. Siden drift av kritiske tjenester kan fortsette selv om forbindelse med BNHQ faller ut. Ulempen er økt kompleksitet, og flere områder for eventuell feilsøking, samtidig som det stilles høyere krav til drift, vedlikehold og lagringsplass.

5.4 Redundans og skalerbarhet

STP er konfigurert i svitsjer selv om nettverk designet ikke har noen trekant topologi av svitsjer. STP gjør nettverket mer robust og skalerbart, men øker samtidig kompleksiteten som går i kontrast med designkrav 8 om minimering. Etherchannel er tilsvarende ikke strengt nødvendig, men gir økt redundans og skalerbarhet som møter designkrav 9 og 11, og støtter prinsippene motstandsdyktig og kapabel.

5.5 Sikkerhetsovervåking, logging og arkitektur

Security Onion serveren i BNHQ mottar speilet trafikk fra nettverksenhetene ved bruk av ERSPAN og samler samtidig inn systemlogger via syslog. Dette gir en sentralisert løsning for overvåking og loggføring som tilfredsstiller designkrav 4. Løsningen bidrar til sikkerhetsmessig overvåking og sporbarhet, og møter designkrav 7 siden plattformen er åpen og kostnadsfri slik at det kan driftes med dagens ressurser. Løsningen kan derimot forbedres, ved f.eks. bruk av SNMP-protokollen. Protokollen gir muligheten til å hente

informasjon om ressursbruk, grensesnittstatus og trafikkmengde, noe som komplementerer overvåkingen fra Syslog og Security Onion.

Hub-spoke arkitekturen for datatrafikk gjør det hensiktsmessig å ha en sentral Security Onion server ved BNHQ. Til gjengjeld påvirker arkitekturen både redundansen og autonomien i hvert bygg. Arkitekturen er også sårbar hvis BNHQ faller ut. Datatrafikk mellom byggene vurderes som lite sannsynlig, og all trafikk ut mot internett må uansett via BNHQ grunnet tilkoblingen til ISP. Derfor vurderes løsningen totalt sett som både praktisk og hensiktsmessig.

5.6 Ikke tekniske aspekter

Teknisk kompetanse hos brukerne er nok begrenset, og det anbefales derfor opplæring innenfor nettverkssikkerhet. Som bevisstgjøring rundt phishingangrep, sosial manipulering, passordhåndtering, og skillet mellom operativ og velferd VLAN.

En alvorlig sårbarhet på leieren er ukontrollerte fysiske områder med nettverksutstyr. Dette bør håndteres umiddelbart gjennom fysisk sikring, vakthold, overvåking og avlåsning av utstyr, som også er reflektert i det fysiske designet vist i figur 7.

Klare rutiner, prosedyrer, og definerte ansvarsområder vil også hjelpe ved en hendelsehåndtering. Anbefaler også å øke beredskapen i form av reservedeler, back-up løsninger og øvelser på nedetid.

5.7 Test og verifikasjon

En tydelig svakhet ved test og verifikasjon er en komplett samlet test med alle funksjonene kombinert. Tvilstomt at de funksjonene som testet i Packet Tracer skal lede til problemer når de blir kombinert, men det kan ikke utelukkes. Mangel på samlet test gjorde også at test av nettverksovervåking ble utfordrende, hver av SYSLOG, SPAN og Security Onion fungerte derimot hver for seg. Samtidig ble ikke 802.1X standarden verifisert, samt loggføringsfunksjonen til RADIUS. Dette er kritiske mangler, siden RADIUS stiller en viktig tilgangskontroll for designet av nettverket. Grunnen til mangelene er uforventede utfordringer og tid til disposisjon.

6 Konklusjon

Designet for nettverket oppfyller de fleste av de definerte designkravene med en god balanse mellom sikkerhet, funksjonalitet og tilgjengelige ressurser. Løsningen tar hensyn til de ideelle egenskaper og prinsippene for forsvarbar INI, og nettverket fremstår robust, autonomt og skalerbart. Enkelte løsninger øker kompleksiteten, men dette anses som akseptabelt målt opp mot sikkerhet, redundans og autonomi.

Det mangler en fullstendig samlet test, men det er lite sannsynlig at det skal skape noe store problemer. Derimot mangler det verifikasjon av 802.1x-standaren og RADIUS-loggføring, noe som utgjør en kritisk svakhet for tilgangskontroll. Mangel på samlet test av nettverksovervåkning skaper også usikkerhet til endelig løsning. Dette bør adresseres.

Det er flere tiltak som reduserer sårbarhetene i nettverket, men å eliminere alle sårbarheter for et nettverk er ikke realistisk. Tid, kompetanse og ressurser til rådighet har også utgjort begrensninger. Utfra forutsetningene vurderes likevel designet som akseptabelt innenfor sikkerhet og forsvarsbarhet for ugraderte systemer. For graderte systemer bør det derimot implementeres ytterligere sikkerhetstiltak, overvåking, kryptering, strengere tilgangskontroll og spesielt implementering av brannmur.

Sammenlignet med utgangspunktet for nettverket i Rukla-leir er sikkerheten, dokumentasjon og beredskapen vesentlig forbedret, samtidig som funksjonaliteten og brukervennligheten er bevart til et akseptabelt nivå. Rapportens løsning anses derfor som god, og når løsningene er blitt verifisert, anbefales umiddelbar implementasjon.

7 Referanseliste

- [1] E. Flydahl, *ING3508 MilitærInformasjonsinfrastruktur-Kompendium*, Lillehammer: Forsvarets høyskole/Cyberingeniørskolen, 2024.
- [2] ManageEngine, “*Securing networks with DHCP snooping*”, ManageEngine, 2024. Hentet fra: <https://www.manageengine.com/products/eventlog/kb/server/dhcp-snooping.html>
- [3] Cisco, “*Configuration Guide for Catalyst 3850 — Consolidated (Release 3.2.0 SE)*”, Cisco, 2014. Hentet fra: https://www.cisco.com/en/US/docs/switches/lan/catalyst3850/software/release/3.2_0_se/multibook/configuration_guide/b_consolidated_config_guide_3850_chapter_0110110.html
- [4] Cisco, “*Spanning Tree PortFast BPDU Guard Enhancement*”, Cisco, 2006. Hentet fra: <https://www.cisco.com/c/en/us/support/docs/lan-switching/spanning-tree-protocol/10586-65.html>
- [5] Cisco, “*Configuring Dynamic ARP Inspection (Catalyst 2960-XR)*”, Cisco, 2017. Hentet fra: https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst2960xr/software/15-2_5_e/configuration_guide/b_1525e_consolidated_2960xr_cg/b_1525e_consolidated_2960xr_cg_chapter_01000110.pdf
- [6] Security Onion Solutions, “*Software*”, Security Onion Solutions, 2025. Hentet fra: <https://securityonionsolutions.com/software>
- [7] Cisco, “*NID Controller Book*”, Cisco, 2018. Hentet fra: https://www.cisco.com/c/en/us/td/docs/switches/metro/me1200/controller/guide/b_nid_controller_book/b_nid_controller_book_chapter_010101.pdf
- [8] Cisco, “*Configuration Guide for Catalyst 3850 — Consolidated 16.3*”, Cisco, 2016. Hentet fra: https://www.cisco.com/c/en/us/td/docs/switches/lan/catalyst3850/software/release/16-3/configuration_guide/b_163_consolidated_3850_cg/b_163_consolidated_3850_cg_chapter_01001010.pdf

- [9] Cisco, “*EtherChannel Configuration Guide*”, Cisco, 2013. Hentet fra:
https://www.cisco.com/c/en/us/td/docs/routers/access/1900/software/configuration/guide/Software_Configuration/etherchannel.html
- [10] Cisco, “*Secure Shell (SSH) Configuration Guide*”, Cisco, 2019. Hentet fra:
<https://www.cisco.com/c/en/us/support/docs/security-vpn/secure-shell-ssh/4145-ssh.html>
- [11] Cisco, “*Network Time Protocol (NTP) Configuration Guide*”, Cisco, 2018. Hentet fra:
<https://www.cisco.com/c/dam/en/us/td/docs/ios-xml/ios/bsm/configuration/xr-3se/3650/bsm-xr-3se-3650-book.html>
- [12] Cisco, “*Tunneling – Overview of Tunneling Technologies*”, Cisco, n.d. Hentet fra:
<https://www.cisco.com/c/en/us/products/ios-nx-os-software/tunneling/index.html>
- [13] NetworkLessons, “*GRE Tunnel Key*”, NetworkLessons, n.d. Hentet fra:
<https://networklessons.com/ip-routing/gre-tunnel-key>
- [14] Cisco Community, “*Understanding VRF Lite*”, Cisco, 2023. Hentet fra:
<https://community.cisco.com/t5/networking-knowledge-base/understanding-vrf-lite/ta-p/5053805>
- [15] Firewall.cx, “*Cisco GRE over IPSec Configuration Guide*”, Firewall.cx, n.d. Hentet fra: <https://www.firewall.cx/cisco/cisco-routers/cisco-router-gre-ipsec.html>
- [16] Cisco, “*Configuring IEEE 802.1X Port-Based Authentication*”, Cisco, 2019. Hentet fra:
https://www.cisco.com/c/en/us/td/docs/ios-xml/ios/sec_usr_8021x/configuration/xr-3se/3850/sec-user-8021x-xr-3se-3850-book/config-ieee-802x-pba.html
- [17] Cisco, “*Configure and Filter IP Access Lists*”, Cisco, 2017. Hentet fra:
<https://www.cisco.com/c/en/us/support/docs/security/ios-firewall/23602-confaccesslists.html>
- [18] TechTarget, “*Port Address Translation (PAT)*”, TechTarget, n.d. Hentet fra:
<https://www.techtarget.com/searchnetworking/definition/Port-Address-Translation-PAT>

[19] Lovdata, “*Forskrift 20. desember 2018 nr. 2053 – Kapittel 6*”, Lovdata, 2018.

Hentet fra:

https://lovdata.no/dokument/SF/forskrift/2018-12-20-2053/KAPITTEL_6#KAPITTEL_6

Vedlegg 1 KOMSS og BIFSMARKS

Ideelle egenskaper for INI og Krav til forsvarbar INI

NATOs CIS-doktrine stiller sentrale krav for en militær INI, for sikkerhet og funksjonalitet når man har en eller flere trusselaktører. Det er derfor formulerte ideelle egenskaper for en militær INI og prinsipper for forsvarbar INI. De viktigste egenskapene er listet under:

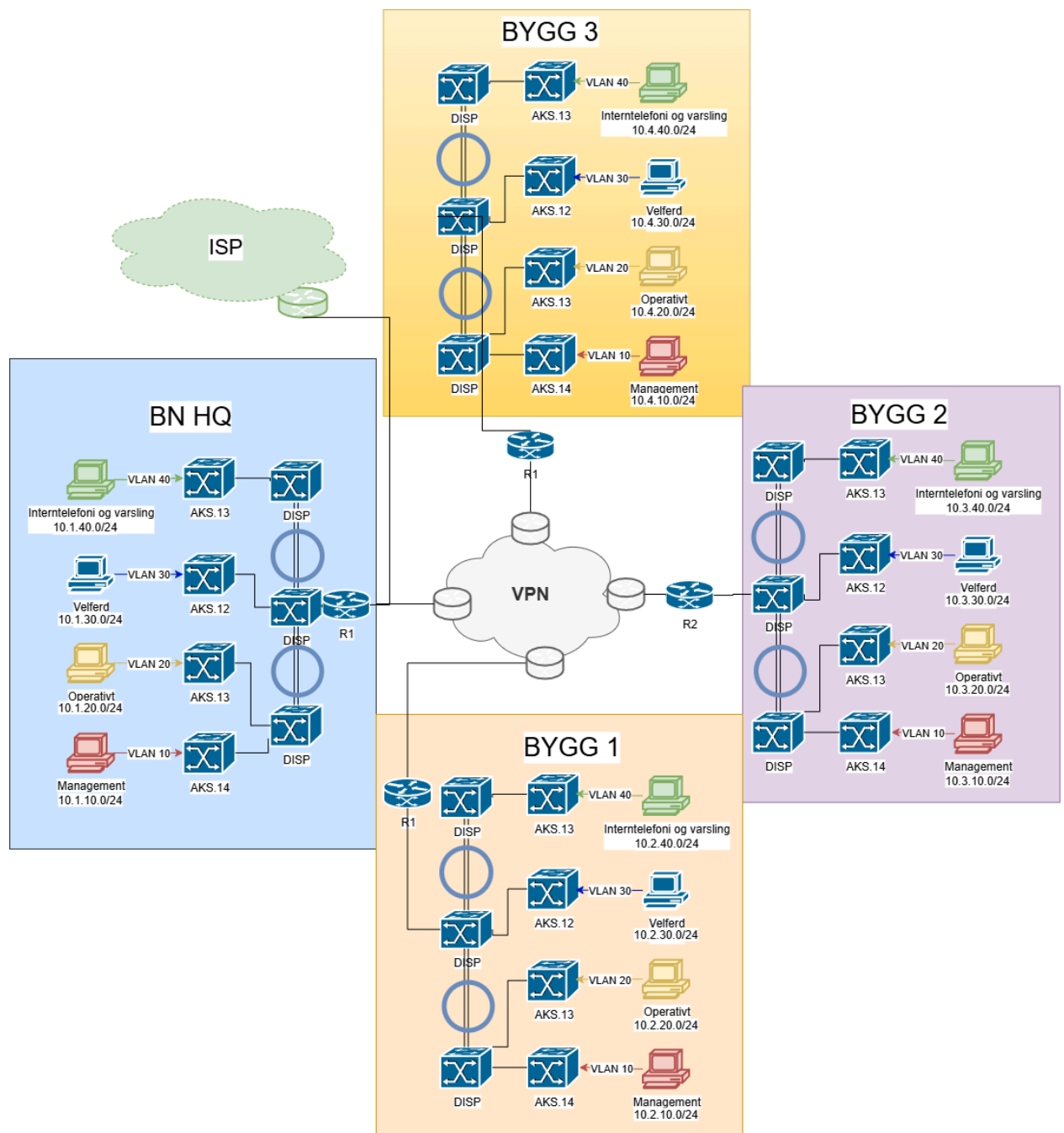
- **Kapabel** går ut på å oppnå funksjonelle behov. Eksempelvis at INI'et skal være designet med kapasitet og prioritet for relevante tjenester.
- **Interoperabel** vil si at løsningene følger standarder og prosedyrer som tilrettelegger for eventuell samarbeid med allierte systemer. Noe som stiller krav til valg av protokoller og konfigurasjoner, samt dokumentasjon av disse.
- **Fleksibel** er at designet må være enkelt å tilpasse nye systemer og behov.
- **Skalerbar** vil si at nettverket kan håndtere økning i brukere eller tjenester uten endringer i arkitektur.
- **Motstandsdyktig** vil si at nettverket har robusthet og redundans mot feil eller angrep. Eksempelvis ved redundans av at det er flere stier mellom svitsjer og rutere.
- **Autonom** vil si at INIet har en lokal funksjonalitet for kritiske lokale tjenester ved tapt sentral konnektivitet.
- **Rettidig** stiller krav til at tidskritiske tjenester leveres når det skal.
- **Beredskapsklar** vil si at INI'et må være klar for respondering av uforutsette hendelser. Dette kan forbedres ved god dokumentasjon, overvåking, gode prosedyrer samt reservedeler.
- **Sikker** baserer seg på konfidensialitet, integritet og tilgjengelighet.

Prinsipper for en forsvarbar INI

Prinsipper for forsvarbart INI er evnen til deteksjon, respons og begrensning av en angriper. Cyberforsvaret lister fem prinsipper på hvordan å innrette en INI til å være forsvarbar:

- **Kontrollert** vil være kontrollmekanismer mot bruk som er imot sikkerhetspolicyer.
- **Oppdatert** vil si at tjenester og systemer skal være sikkerhetsoppdaterte.
- **Minimert** vil si å redusere tjenester til det som er behovet, ved eksempelvis å deaktivere unødvendige tjenester.
- **Sikkerhetsmessig overvåket** er prinsippet om å avdekke sikkerhetsturende hendelser. Dette kan oppnås med loggsamling og trafikkovervåkning
- **Sporbar** er prinsippet om at aktiviteter kan knyttes til enhet og bruker. Noe som kan oppnås med trafikkovervåking og logging.

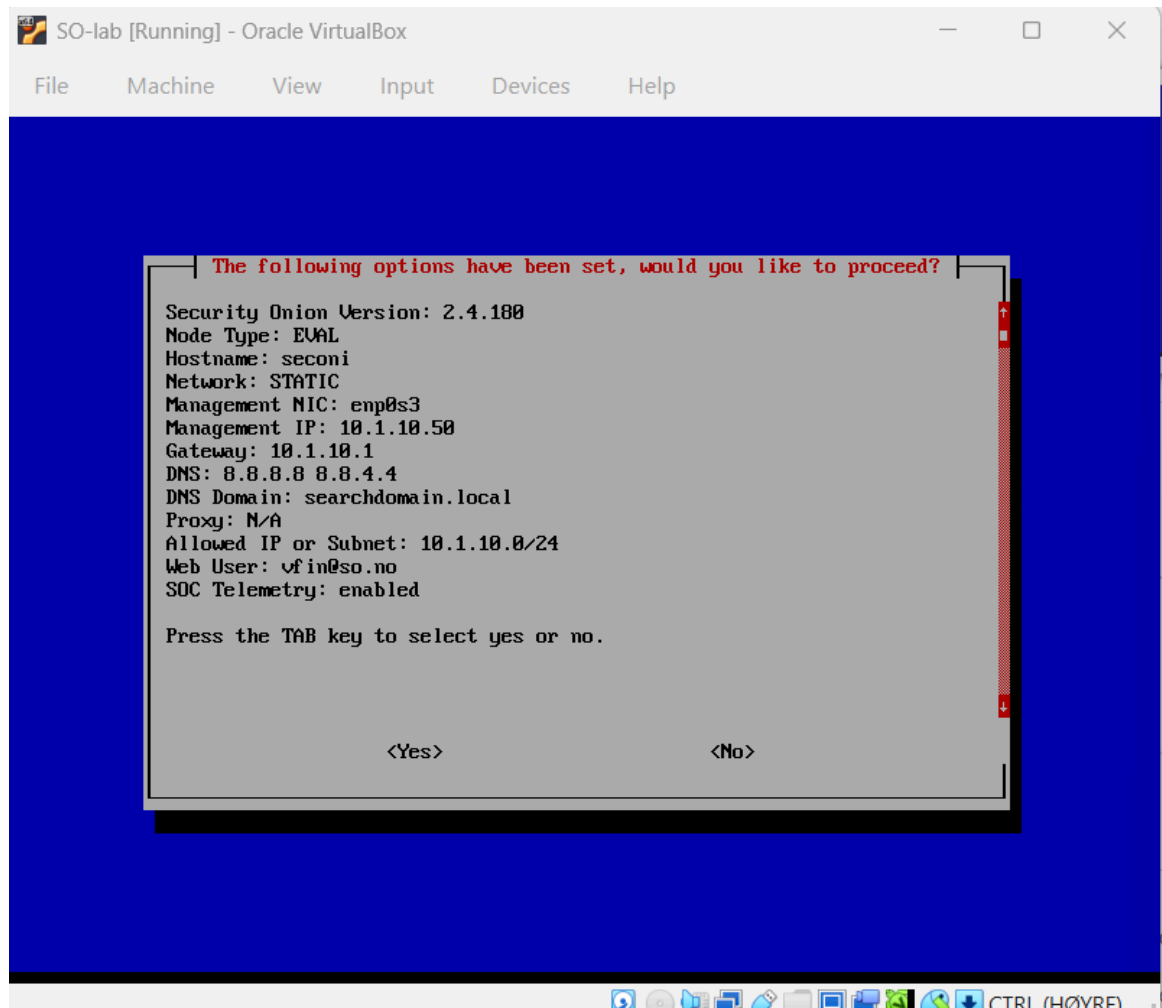
Vedlegg 2 Detaljert nettverkskisse



Vedlegg 4 Nettverksovervåkning

Security onion oppsett

Det ble lastet ned et Security Onion image som ble kjørt gjennom Oracle Virtualbox for å kunne fange opp nettverksdata. Dette skulle da bli brukt sammen med ERSPAN for å fange opp nettverkstrafikk på de forskjellige enhetene, og med SYSLOG for å få systemmeldinger fra nettverket.



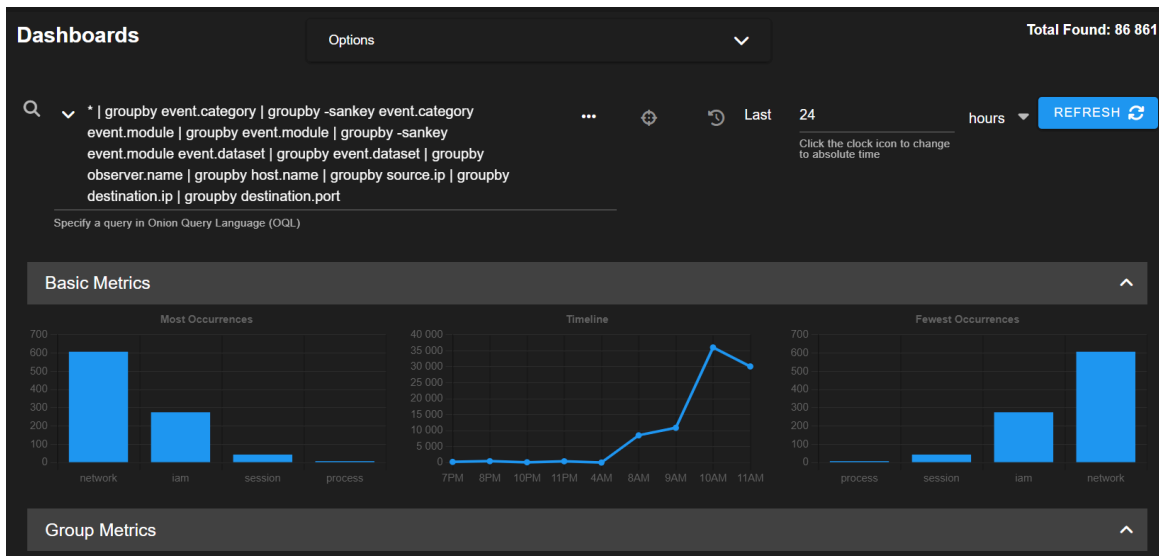
Her er fullt oppsett til security onion VMen, med IPer koblet til management VLANet

Security Onion Status		
Container	Status	Details
so-dockerregistry	running	Up 2 hours
so-elastalert	running	Up 2 hours
so-elastic-fleet	running	Up 2 hours
so-elastic-fleet-package-registry	running	Up 2 hours (healthy)
so-elasticsearch	running	Up 2 hours
so-idstools	running	Up 2 hours
so-influxdb	running	Up 2 hours (healthy)
so-kibana	running	Up 2 hours
so-kratos	running	Up 2 hours
so-nginx	running	Up 2 hours (healthy)
so-sensoroni	running	Up 2 hours
so-soc	running	Up 2 hours
so-strelka-backend	running	Up 2 hours
so-strelka-coordinator	running	Up 2 hours
so-strelka-filestream	running	Up 2 hours
so-strelka-frontend	running	Up 2 hours
so-strelka-gatekeeper	running	Up 2 hours
so-strelka-manager	running	Up 2 hours
so-suricata	running	Up 2 hours
so-telemetry	running	Up 2 hours
so-zeek	running	Up 2 hours (healthy)

■ This onion is ready to make your adversaries cry!

[ufin@secon1 ~]\$

Skjerm bilde som viser alle tjenestene, og verktøyene som security onion leverer, med status.



Oversikt over hvordan dashboard i security onion ser ut.

```
Syslog config
conf t
service timestamps log datetime msec
service sequence-numbers
logging on
logging 10.1.10.50
logging trap informational
logging facility local7
```

```
Syslog logging: enabled (11 messages dropped, 10 messages rate-limited,
                  0 flushes, 0 overruns, xml disabled, filtering disabled)
  Console logging: level debugging, 87 messages logged, xml disabled,
                  filtering disabled
  Monitor logging: level debugging, 0 messages logged, xml disabled,
                  filtering disabled
  Buffer logging: disabled, xml disabled,
                  filtering disabled
  Logging Exception size (4096 bytes)
  Count and timestamp logging messages: disabled

No active filter modules.

  Trap logging: level informational, 100 message lines logged
    Logging to 10.1.10.50(global) (udp port 514, audit disabled, link up),
    3 message lines logged, xml disabled,
    filtering disabled
```

Syslog ble aktivert og testet på HUB ruter. På bildet ovenfor kan det sees at logging ble etablert og sendt mot IPen til security onion serveren

Erspar

Erspar er ikke mulig å bruke på ruterne vi har så det måtte bli testet med kun

ERSPAN konfig

```
conf t
monitor session 1 type erspan-source
source interface Gi1/0/5 both
destination
erspan-id 101
ip address 10.1.10.50
origin ip address 10.1.10.10
mtu 1464
no shut
end
```

SPAN config

```
conf t
monitor session 1 source interface Fa1/1 both
monitor session 1 destination interface Fa1/7
end
```

Samlet konklusjon

Hver av delene er testet og fungerer hver for seg, men samlet test har ikke blitt fullført, og ettersom mye av nettverksutstyret er utdatert så fungerer ikke f.eks. ERSPAN. Så i konklusjon, så med mer tid hadde det vært mulig å sette opp hele systemet med mer tid og testing. Så løsningen har blitt til dels verifisert.